

SoK: Privacy Attacks on Machine Learning via Explainable AI

Abdullah Caglar Oksuz
Case Western Reserve University
abdullahcaglar.oksuz@case.edu

Anisa Halimi
IBM Research
anisa.halimi@ibm.com

Erman Ayday
Case Western Reserve University
erman.ayday@case.edu

Abstract

Machine learning explanations reveal model behavior beyond predictions, creating attack surfaces for model confidentiality and data privacy. We systematize 25 studies that exploit explanations for model extraction, membership inference, and model inversion, treating attribute inference as partial inversion. Existing work is often labeled only black- or white-box, obscuring substantial differences in what explanation signal reaches an adversary. We therefore separate model knowledge from explanation acquisition and identify five paths: target-released, attacker-derived, secondary disclosure, privileged access, and released global artifacts. Across these paths, explanations reduce extraction cost, expose membership signals through explanation statistics, recourse distance, and explanation-guided robustness, and support spatial or algebraic reconstruction of private inputs. We compare system and threat models, explanation signals, auxiliary knowledge, target models, modalities, query budgets, evaluation metrics, reported performance, and defenses. Our analysis shows that no explanation family is uniformly unsafe and no defense is uniformly effective. Risk depends on which signal is exposed, how it is acquired, which asset is targeted, and what the attacker already knows. We argue that explanation privacy should therefore be evaluated as an end-to-end disclosure problem, with defenses matched to the acquisition path and protected asset.

1 Introduction

Explainable artificial intelligence (XAI) releases information beyond the prediction itself. A feature-importance explanation identifies which dimensions mattered; a saliency map exposes spatial sensitivity; a counterfactual identifies a nearby point with a different outcome; a local surrogate approximates a decision region; and an influence-style explanation relates a prediction to training records. These artifacts serve legitimate goals such as debugging, recourse, auditing, and user understanding. They are useful precisely because they reveal

structure beyond a label or confidence score. The same structure can become an attack surface.

A growing line of work has exploited explanations for three recurring goals. *Model extraction* uses gradients, feature-importance explanations, counterfactuals, or local surrogates to reproduce model behavior with fewer or more informative queries [2, 23, 24, 31]. *Membership inference attacks (MIAs)* use explanation statistics, counterfactual distance, influence, or explanation-guided perturbations to decide whether a record was used for training [18, 34, 39]. *Model inversion* reconstructs all or part of a private record from explanation outputs, including sensitive-attribute inference as partial reconstruction [7, 20, 42, 50]. These attacks affect different assets: model extraction primarily compromises model confidentiality, membership inference targets training-data privacy, and inversion may target either training records or private inputs submitted at inference time.

The gap is therefore not a missing catalog of explanation privacy risks. Recent surveys already organize attacks and privacy-preserving explanations [4, 28], while SoKs on XAI in cybersecurity and adversarial settings cover broader offensive and defensive uses [26, 30]. The unresolved problem is *comparability*: papers use similar labels for materially different security boundaries. “Black-box” may describe a label-only API, a prediction-plus-counterfactual service, an oracle returning the full input gradient, or a model with hidden parameters but a rich explanation tensor. These are not equivalent capabilities. An explanation may also come from the attacker’s own query, a surrogate constructed by the attacker, another user’s leaked report, or privileged model-owner access. Collapsing these settings obscures deployment realism and makes defense claims appear broader than the threat models they actually cover.

We retain the attack-family view expected by a privacy audience, namely model extraction, membership inference, and model inversion, but analyze every study through one system model. It separates (i) the protected asset and attack goal, (ii) model and training-data knowledge, (iii) prediction output, (iv) explanation acquisition, (v) auxiliary, shadow, and sur-

rogate resources, and (vi) query budget and adaptivity. This makes it possible to compare modalities, model classes, metrics, and the incremental contribution of explanations without treating incompatible threat models as equivalent.

This analysis exposes four recurring security properties. First, **model knowledge and explanation disclosure are orthogonal**: hidden parameters do not prevent a service from exposing a gradient oracle with near-white-box learning value [23, 24]. Second, **the target need not release the explanation**: attacker-derived explanations can preserve attacks after an explanation endpoint is disabled [48, 50]. Third, **explanation reports are sensitive derived data**: several inversion attacks target a report created for another user and later shared, intercepted, or compromised [20, 42, 50]. Fourth, **defenses are path-specific**: differential privacy (DP), output perturbation, rate limiting, and access control protect different assets and disclosure channels.

Contributions. We make the following contributions:

- We systematize 25 core explanation-assisted attack studies across model extraction, membership inference, and model inversion, including attribute inference, while preserving the threat-model and metric differences needed to interpret their results.
- We introduce an *explanation-acquisition* taxonomy comprising target-released, attacker-derived, secondary disclosure, privileged access, and released global artifact, separated from conventional model knowledge and prediction access.
- We compare the operational role of explanations, attack assumptions, modalities, metrics, and factors that determine leakage, rather than ranking attacks whose evaluation protocols are not comparable.
- We map defenses to the assets and acquisition paths they protect and derive reporting requirements for evaluating marginal leakage, low-FPR membership risk, extraction cost, and remaining disclosure channels.

2 Scope and Methodology

2.1 Attack Scope

We focus on attacks whose offensive procedure *uses an explanation or interpretability artifact*. The three core families are:

Model extraction. The adversary learns a surrogate, parameters, or functionally equivalent model. Strictly, this targets model confidentiality rather than an individual’s privacy. We retain it because the machine learning (ML) privacy literature commonly analyzes privacy and model confidentiality together [37], explanations are a direct extraction primitive, and an extracted surrogate can enable downstream membership or inversion attacks.

Membership inference. The adversary decides whether a candidate record was used to train the target model.

Model inversion. The adversary reconstructs private information represented by, or associated with, a record. We include sensitive-attribute inference as *partial inversion*: the output is a hidden feature rather than a full record.

We exclude attacks that merely manipulate an explanation without a privacy or model-confidentiality objective (e.g., explanation evasion), generic adversarial examples, and gradient leakage from distributed training when the gradient is a training communication artifact rather than an explanation. Gradient-reconstruction attacks such as DLG and iDLG are relevant lineage for understanding gradient sensitivity, but they are outside the core corpus for this reason [44, 49, 52]. We also exclude prediction-only attacks except as baselines. Linkage and re-identification from counterfactuals are discussed as adjacent privacy objectives but are not forced into our three-family comparison [11].

2.2 Corpus Construction and Cutoff

Our objective is analytical systematization rather than a PRISMA-style review. Starting from the papers assembled for this manuscript, we cross-checked the closest surveys and SoKs [4, 26, 28, 30] and used their references plus targeted freshness checks through **August 2, 2026** to identify missing work. A study enters the *core attack corpus* if it evaluates one of our three attack families, the attack actually consumes an explanation signal, and the threat model is specific enough to classify the acquisition path. The final corpus contains **25 studies**: 13 on extraction, nine on membership inference, and four on inversion or attribute inference, with one study spanning extraction and membership inference. Recent preprints are retained only when they materially broaden the threat-model or modality landscape.

Unlike Allana et al.’s [4] broader 57-study scoping review and Nguyen et al.’s [28] explanation-type taxonomy, our unit of analysis is the *attack path* from explanation acquisition to a privacy or model-confidentiality objective. That narrower scope enables deeper comparison of operational assumptions and quantitative evidence.

2.3 Coding Dimensions

For each core study we record the attack family, protected asset, model knowledge, prediction output, explanation signal and acquisition path, auxiliary data, query budget, target model class, modality, success metric, representative result, and evaluated defenses. We do not force heterogeneous metrics into a synthetic ranking: 93% extraction fidelity, 0.93 MIA AUC, and 0.90 image SSIM are different security properties. Instead, Sections 5–7 compare results within each fam-

ily and Section 8 identifies where evaluation choices block stronger conclusions.

3 Background and Terminology

3.1 Explanation Outputs

Let a model f_D be trained on dataset D . A conventional prediction service returns a prediction output $o(x)$, which may be a hard label or a confidence vector. An explanation mechanism additionally returns or makes available an artifact

$$e(x) = \phi(f_D, x; R), \quad (1)$$

where R denotes any additional resources used by the explainer, such as a reference or background dataset, training examples, model gradients, or a counterfactual generator. For security analysis, $e(x)$ is not a single kind of output. Its content and the resources used to compute it determine what information may cross a trust boundary.

Feature-importance methods include model-agnostic local surrogates such as LIME [36], game-theoretic attributions such as SHAP [19], and backpropagation-based methods for deep neural networks (DNNs), including Integrated Gradients [41], Grad-CAM [38], and layer-wise relevance propagation (LRP) [5]. Counterfactual explanations (CFs) return a nearby input whose prediction differs and are commonly used for recourse [25, 43]. Influence functions relate predictions or losses to training examples [16]. These mechanisms expose different mathematical objects: importance vectors, local linear approximations, derivatives, boundary-adjacent examples, or training-record influence. Table 1 summarizes the signals that appear in our corpus.

3.2 Marginal Leakage from Explanations

The correct baseline for an explanation-assisted attack is the same adversary without the explanation signal. Conceptually, for an attack metric M where higher is better,

$$\Delta_{\text{XAI}} = M(A \mid o, e, K, Q) - M(A \mid o, K, Q), \quad (2)$$

where K is auxiliary knowledge and Q is the query budget. For error metrics, the sign is reversed. Equation 2 is intentionally generic: the right family-specific metric may be fidelity at a fixed query budget, query savings at fixed fidelity, TPR at a fixed low FPR, or reconstruction error. The important requirement is to hold the remaining threat model fixed.

Many studies change more than the explanation channel itself, for example the optimizer, query strategy, or architecture. Liu et al. [18] show this explicitly: their stronger MIA depends on both XAI and a new multi-query procedure. By contrast, DTMEA [46] gives a cleaner prediction-only versus prediction-plus-explanation comparison within one multitask design. Throughout this SoK we therefore distinguish *attack performance with XAI* from evidence that isolates Δ_{XAI} .

4 System and Threat Model

4.1 Model Knowledge and Interface Disclosure

Traditional ML privacy work often summarizes attacker knowledge as black-box or white-box. For explanation-assisted attacks, this collapses two different dimensions. *Model knowledge* asks whether parameters, architecture, gradients, or training data are known. *Interface disclosure* asks what the deployed system returns. Milli et al. [23], for example, study an unknown model through an oracle that returns function values and input gradients. The parameters remain hidden, yet the gradient can be a far stronger learning primitive than a hard label. MEGEX [24] similarly treats the target model as externally queryable while using Vanilla Gradient explanations to recover the gradients needed for data-free distillation. Calling these simply “black-box” understates the information channel; calling them white-box incorrectly implies parameter access.

We therefore represent an attack setting as

$$\mathcal{T} = \langle G, K_M, O, A_E, K_D, Q \rangle, \quad (3)$$

where G is the attack goal and protected asset, K_M is model knowledge, O is the prediction output (label, score, etc.), A_E is explanation acquisition, K_D is auxiliary data and knowledge, and Q captures query budget and adaptivity. This representation makes two attacks comparable only when the dimensions relevant to their goal are aligned.

4.2 Explanation-Acquisition Paths

Across the corpus, we identify five recurring ways in which an adversary obtains an explanation signal.

P1: Target-released. The attacker sends a query and the deployed service returns the explanation for that query. Counterfactual extraction [2, 15, 45], explanation-guided MIA [18, 39], and many gradient-oracle extraction studies assume this path. The core control point is the explanation endpoint and its output policy.

P2: Attacker-derived. The target does not need to return the dangerous explanation. The attacker derives a local explanation from target predictions, trains a surrogate model or explainer, or reconstructs an explanation before using it in the privacy attack. XaMEA [48] includes attacks against targets that do not proactively provide explanations; Zhao et al.’s [50] surrogate-explanation pipeline can improve inversion even for a non-explainable target. This path survives a policy that merely disables explanation output.

P3: Secondary disclosure. A legitimate explanation is generated for another data subject and subsequently shared,

Table 1: Explanation signals used in the core corpus. **P1–P5** denote the acquisition paths defined in Section 4.

Signal	Typical scope	Model requirement	Security-relevant content	Acquisition path	Representative studies
Input gradients / saliency	Local	Differentiable model for direct computation	Local derivative, feature sensitivity, decision geometry	P1, P4	Milli et al. [23]; Miura et al. [24]; Shokri et al. [39]
IG / Grad-CAM / LRP	Local	Usually a differentiable neural network; method dependent	Spatial or feature relevance; class-specific structure	P1, P2, P3	Zhao et al. [50]; Liu et al. [18]; Yan et al. [46, 48]
LIME	Local	Model-agnostic query access	Local feature weights and a local surrogate	P1, P2	Oksuz et al. [31]; Yan et al. [47]
SHAP values	Local; Global aggregation	Model-specific or model-agnostic variants	Per-feature marginal contributions; correlations with private inputs	P1, P3, P2	Oksuz et al. [31]; Luo et al. [20]; Toma and Kikuchi [42]; Duddu and Boutet [7]
CF / recourse	Local	Prediction plus counterfactual-generation service	Boundary-adjacent instance, direction and magnitude of change	P1	Aïvodji et al. [2]; Wang et al. [45]; Pawelczyk et al. [34]; Khouna et al. [15]
Influence	Local; training record	Usually model and training-process access	Contribution of training records to loss or prediction	P4	Cohen et al. [6]
Global surrogate	Global	Released or queryable surrogate	Compact approximation of global decision logic	P5	Naretto et al. [27]
Graph substructure	Local	GNN explainer dependent	Important nodes, edges or substructures	P1	Ma et al. [21]

leaked, intercepted, or stolen. Luo et al.’s [20] Shapley feature-inference framework first lets the attacker learn an inverse mapping with its own queries, then assumes access to target customers’ explanation reports. Zhao et al. [50] model prediction and explanation tuples obtained from breached storage, interception, or social sharing; Toma and Kikuchi [42] likewise assume access to another user’s Shapley values. Here the explanation report is itself sensitive derived data, and API rate limiting is not the primary defense.

P4: Privileged access. The attack uses quantities normally available during training, debugging, or model-owner analysis rather than through a prediction service. Cohen et al.’s [6] self-influence MIA belongs here. Gradient leakage from distributed training also belongs to this broader privileged lineage, although it is outside our core corpus because the gradient is not an explanation artifact.

P5: Released global artifact. A global surrogate or interpretable explanation model is released as an artifact. Naretto et al. [27] evaluate membership exposure of global interpretable surrogates. The attack surface persists after release and is not governed by per-query access controls.

4.3 Caller, Data Subject, and Adversary

A separate ambiguity concerns identity. In P1 attacks, the adversary often queries its own record; in P3, it calibrates on its own queries but reconstructs a *different person’s* record from that person’s report. Threat models should therefore name the *caller*, the *data subject*, and the *adversary*. These roles may

coincide, but assuming so can hide the true trust boundary. Stating only “black-box” is therefore incomplete: the model should also specify the prediction output, explanation artifact, acquisition path, auxiliary knowledge, and whose record is being explained.

5 Model Extraction

Model extraction is the largest attack family in the core corpus and exhibits the broadest range of explanation roles. The common objective is to learn a surrogate $\hat{f}$ that agrees with the target f on a query distribution or to recover a functionally equivalent model. Explanations help because they expose more than a class label: a derivative can reveal local parameters, a counterfactual can locate a boundary, a feature-importance vector can guide which features to perturb, and an explanation-alignment loss can supervise the surrogate’s decision logic. The literature evaluates these goals using target-surrogate fidelity, surrogate task performance, query count, and, in a smaller number of studies, similarity between target and surrogate explanations.

5.1 Gradient Explanations

Milli et al. [23] provide the clearest demonstration that the *information content* of an explanation matters more than the generic black-box label. For a linear model, one input-gradient query identifies the weight vector. For a two-layer ReLU network with h hidden units under their stated independence assumptions, the model can be recovered with $O(h \log h)$ input-gradient queries, compared with an $\Omega(dh)$ information requirement for label queries in their analysis. Empirically, a

Table 2: Model extraction attacks using explanations. Results follow each study’s threat model and are not a single leaderboard.

Study	Explanation (path)	Mechanism	Modality	Target models	Evaluation	Representative finding
Milli et al. [23]	Gradients or saliency; P1	Parameter recovery; gradient matching	Image	Linear; two-layer ReLU; convolutional network; VGG11; ResNet-18	Accuracy; queries	MNIST convolutional network: 95% accuracy with 10 gradient queries versus 1,000 label queries; theory gives $O(h \log h)$ gradient queries.
Aivodji et al. [2]	Prediction + CF; P1	Surrogate training on factual and counterfactual pairs	Tabular	Logistic regression; multilayer perceptron	Fidelity; accuracy; queries	Adult: about 93% fidelity with 1,000 queries under marginal-distribution knowledge; CFs remain useful with unknown distribution.
Kuppa and Le-Khac [17]	Prediction + CF; P1	CF-assisted coverage and distillation	Tabular (security)	Gradient-boosted trees; neural networks	Surrogate accuracy; queries	CF-assisted extraction outperforms prediction-only and distillation baselines in the evaluated security setting.
Wang et al. [45]	Prediction + CF + second CF; P1	Two-sided boundary sampling	Tabular	Hidden-parameter classifiers	Fidelity; queries	Two-sided CF information improves extraction efficiency over one-sided CF extraction.
Yan et al. [46]	Prediction + four feature-importance methods; P1	Joint prediction and explanation training	Image	DNNs	Accuracy; explanation MSE	Prediction+explanation gains reach 1.25, 1.53, 9.25, and 7.45 points on MNIST, Fashion-MNIST, CIFAR-10, and CIFAR-100.
Yan et al. [47]	Prediction + Grad-CAM or LIME; P1	Data-free generation with explanation loss	Image	ResNet-34; ResNet-18	Surrogate accuracy	Outperforms DFME and DaST on CIFAR-10 and SVHN; simple explanation perturbation changes attack accuracy by at most 0.65 percentage points.
Yan et al. [48]	Prediction + feature-importance map; P1/P2	Prediction and explanation fusion	Image	DNNs	Accuracy; fidelity	Explanation-assisted variants yield the largest gains on CIFAR-10 and CIFAR-100; attacker-derived explanations preserve part of the advantage.
Miura et al. [24]	Soft prediction + gradient explanation; P1	Gradient-guided data-free generation	Image	ResNet-34; ResNet-18; LeNet-5	Surrogate accuracy; queries	CIFAR-10: 81.13% accuracy at 2.5M queries versus 20M for reproduced DFME; 91.61% at 20M queries.
Oksuz et al. [31]	Label + LIME or SHAP; P1	Explanation-guided active traversal	Tabular	Interpretable classifiers	Similarity; accuracy; queries	High similarity in several low-complexity settings; 100 queries for Breast Cancer logistic regression; pixel-level image explanations are ineffective.
Ezzeddine et al. [8]	Prediction + private or non-private CF; P1	Knowledge distillation with CFs	Tabular	DNNs	Agreement; accuracy	Non-private CFs improve extraction; DP-generated CFs reduce agreement toward no-CF baselines.
Khouna et al. [15]	Prediction + locally optimal CF; P1	Tree Reconstruction Attack	Tabular	Decision trees; random forests	Fidelity; queries	Exact tree recovery with orders-of-magnitude fewer queries than PathFinding in many settings.
Ma et al. [21]	Prediction + GNN explanation; P1	Alignment and guided augmentation	Graph	Five GNN architectures	AUC; fidelity; rank correlation	NCI109 with Graph-CAM: +11.59 percentage points of fidelity over the prediction-only extraction baseline; gains vary by architecture and explainer.
Otto et al. [32]	Factual + exact or robust CF; P1	Geometric parameter recovery	Tabular	Linear classifiers	Exact recovery; queries	Exact parameter recovery from a small number of targeted queries under exact-oracle assumptions.

MNIST convolutional model reaches 95% accuracy after 10 gradient queries compared with 1,000 label queries; VGG11 and ResNet-18 still show roughly an order-of-magnitude reduction to reach a lower accuracy target. This is not conventional white-box access because the model parameters can remain secret, but the explanation oracle exposes a high-bandwidth learning primitive.

MEGEX [24] pushes the same insight into data-free extraction. Data-free model extraction estimates gradients of the target indirectly through repeated prediction queries; MEGEX consumes Vanilla Gradient explanations directly and proves equivalence to the corresponding white-box data-free knowledge-distillation update under its formulation. On CIFAR-10, the reproduced DFME baseline reaches 81.13% surrogate accuracy at 20M queries, while MEGEX reaches the same accuracy at 2.5M and 91.61% at 20M. The absolute

budgets are large, so this is not evidence that every gradient-explanation API is cheaply exploitable. It is evidence that returning raw or nearly raw derivatives can collapse a major source of query cost.

Processed gradients complicate any monotonic “more interpretable means more leakage” claim. MEGEX [24] finds SmoothGrad and Integrated Gradients useful on Fashion-MNIST and SVHN but not equally effective on CIFAR-10. The key variable is not “gradient-based XAI” alone, but how faithfully the released explanation preserves the optimization signal the attacker needs.

5.2 Counterfactual Explanations

Counterfactual explanations are operationally attractive because they are designed to reveal a nearby point that changes

the decision. This directly supplies boundary information. Aïvodji et al. [2] show that a surrogate can reach about 93% fidelity on Adult with 1,000 queries even when the adversary knows only feature marginals; without knowledge of the data distribution, their CF-based attack can outperform a traditional extraction baseline using eight times more labels and full distribution knowledge. Providing multiple and diverse counterfactuals further improves extraction, illustrating a direct tension between explanation diversity for users and boundary coverage for attackers.

DualCF [45] queries a counterfactual and then a counterfactual of that counterfactual, obtaining information from both sides of the boundary. Kuppa and Le-Khac [17] use CFs to expand attack data across classes and combine them with distillation in cybersecurity models. More recent work moves from approximate to exact extraction. Khouna et al. [15] use their Tree Reconstruction Attack to recover decision trees and random forests from locally optimal counterfactuals, reaching functional equivalence with substantially fewer queries than PathFinding in many settings. Otto et al. [32] analyze exact and robust counterfactual queries for linear classifiers and derive parameter-recovery results under explicit oracle assumptions.

This progression matters because later work shows that, for structured model classes, a CF oracle can be sufficient for exact functional recovery. Defenses based only on detecting high query volume therefore become less compelling as the required budget falls.

5.3 Feature-Importance-Guided Extraction

Not all extraction attacks treat the explanation as a direct parameter oracle. AUTOLYCUS [31] uses LIME and SHAP to decide *where to query*: explanation-identified important features and local boundaries guide active traversal, after which the attacker retrains a surrogate. This role is closer to active-learning guidance than gradient inversion. Across six tabular and mixed-type datasets and several interpretable model classes, the attack obtains high similarity with comparatively small budgets in favorable settings; for Breast Cancer logistic regression it reports high similarity with 100 queries. A direct query ratio against equation solving cannot be established for that dataset because the baseline does not report a corresponding query count. Its limitations are equally informative: pixel-wise LIME and SHAP are not sufficiently informative for the evaluated image setting, and complex trees require larger and more diverse auxiliary coverage. This is evidence that modality and semantic granularity of an explanation can dominate the nominal XAI method.

A series of attacks uses explanations as an auxiliary supervised target. DTMEA [46] jointly learns predictions and explanations and reports larger gains on CIFAR-10 and CIFAR-100 than on MNIST and Fashion-MNIST. DMEA [47] uses an explanation loss in a data-free setting; XaMEA [48]

fuses image explanations and predictions and also studies attacker-derived variants; and EGSteal [21] transfers this idea to graphs. These attacks target not only output fidelity but aspects of *decision logic*, so evaluations should state whether success means label agreement, parameter recovery, or explanation alignment.

5.4 Evaluation of Model Extraction

The dominant metrics are test accuracy of the surrogate, fidelity or agreement with the target, and query count. These capture different objectives. High test accuracy can coexist with low agreement when both models generalize differently; high fidelity on the natural test distribution can miss unobserved branches of a tree. Khouna et al. [15] therefore evaluate fidelity on uniformly sampled input-space points in addition to test-distribution evaluation. This is preferable when claiming functional recovery.

Query count is equally essential because the principal benefit of explanations is often efficiency. Reporting only the final surrogate accuracy can hide whether XAI saves 10 queries or millions. For learning-based extraction, we recommend an *anytime fidelity curve* versus target queries and a fixed-fidelity query comparison. When one explanation request internally performs many model evaluations (e.g., model-agnostic SHAP or LIME), studies should also state whether the cost metric counts external requests or total target-model evaluations. Without that accounting, “one explanation query” can represent very different server-side work and information release.

Cross-paper query-efficiency claims also depend on baseline strength. Milli et al. [23] compare labels and gradients as different learning primitives, while MEGEX [24] reproduces a data-free extraction baseline under closely matched architectures and training choices. Aïvodji et al. [2] explicitly vary architecture and distribution knowledge, showing that counterfactual information remains useful as those assumptions are weakened. Other comparisons change several factors at once, including prediction precision, auxiliary data, surrogate architecture, and query strategy. We therefore do not rank extraction methods across papers. A defensible explanation-versus-prediction comparison should hold these factors fixed and vary only the additional explanation channel.

The extraction literature supports a spectrum rather than a single claim: raw gradients can act as near-parameter oracles; counterfactuals expose boundary geometry; feature importance guides adaptive querying; and explanation alignment supplies an extra training target. The relevant security question is which learning primitive the interface reveals and at what query cost.

6 Membership Inference

Membership inference asks whether a record z was included in the target training set. Explanations create membership signals in three main ways: (i) the explanation vector itself has different statistics for members and non-members; (ii) an explanation reveals distance or geometry related to the decision boundary; or (iii) it guides perturbations that expose a difference between members and non-members in robustness. These mechanisms are related to generalization and memorization, but they are not interchangeable. We retain each study’s original metrics, while emphasizing true-positive rate (TPR) at a fixed false-positive rate (FPR) when available because it captures high-confidence leakage that average accuracy or area under the ROC curve (AUC) can obscure.

6.1 Explanation Statistics

Shokri et al. [39] provide the foundational analysis of membership leakage through feature-based explanations. For backpropagation-based explanations, variance (or equivalently related norms in their experiments) can separate members from non-members because explanation magnitude or variance relate to a point’s position relative to the learned boundary. A learned attack on the entire explanation vector is slightly stronger than a variance-only threshold. Integrated Gradients and LRP also leak membership, although generally less than raw gradient explanations in their evaluated settings. Importantly, leakage varies with input dimensionality, number of classes, and overfitting; “gradient explanation = vulnerable” is not a constant attack rate.

Global explanations introduce a different channel. Naretto et al. [27] show that an interpretable global surrogate can be more vulnerable to MIA than the original black-box model. The risk here persists after the surrogate is released and is governed by how the global explainer approximates or overfits the target, not by repeated local explanation queries.

Cohen et al. [6] use self-influence to identify membership. The result is relevant to explanation leakage but has a substantially stronger access model: self-influence is computed with privileged model and training information. We therefore classify it separately from public explanation APIs. Combining it with external attacks under a single “white-box versus black-box XAI” ranking would obscure deployability.

6.2 Counterfactual Distance

Algorithmic recourse creates a natural geometric statistic: the distance from a point to a counterfactual. Pawelczyk et al. [34] formalize counterfactual-distance (CFD) attacks and a likelihood-ratio version using this distance. Their results are notable for heterogeneity. On HELOC with CCHVAE recourse, the LRT reaches AUC 0.679 and TPR 5.13% at 1% FPR; several Adult and Diabetes configurations remain close

to random. Thus the existence of a CF API does not imply uniformly strong MIA. Leakage depends on the model, data geometry, and recourse algorithm.

Kuppa and Le-Khac [17] also use counterfactual neighborhoods in a black-box membership attack. Ezzeddine et al. [9] later show a sizeable empirical increase when counterfactual information is added to an MIA on EEG: accuracy and recall rise from 58% without CFs to 77% with CFs in the reported baseline setting. Because the latter is a preprint and uses a different evaluation protocol, it should be read as evidence that CF information can amplify leakage, not as a direct ranking over Pawelczyk’s attacks.

6.3 Explanation-Guided Robustness

Liu et al. [18] shift the MIA signal from the explanation vector to *model robustness under explanation-guided perturbation*. The attacker ranks pixels using SmoothGrad, VarGrad, Integrated Gradients, Grad-CAM, Grad-CAM++, LIME, or SHAP, perturbs most- or least-relevant regions, and classifies the resulting confidence-degradation trajectory. Across the seven explanation methods in a representative CIFAR-100 setting, reported AUCs are roughly 0.915–0.931 and TPR at 0.1% FPR is 2.2–3.7%. These numbers are strong, but the paper’s ablations are crucial: an explanation-free segmentation and perturbation strategy also improves substantially over older baselines. The result therefore demonstrates a strong *explanation-assisted attack pipeline*; its raw improvement should not be attributed entirely to XAI.

Ma et al. [22] pursue a related idea under stricter label-only output. Feature importance guides high-dimensional neighborhood sampling, from which the attacker derives an attributed-neighborhood consistency signal and approximates confidence. The attack explicitly selects “forgettable” or vulnerable records to obtain high precision at low FPR while sacrificing coverage. This is a meaningful privacy threat because an attacker may only need to identify some users with high confidence, but the coverage trade-off must accompany the headline TPR.

DeepLeak [12] broadens the explanation-method coverage and directly studies leakage drivers and mitigations across 15 XAI techniques. For this SoK, the important result is broader than the reported MIA improvement: explanation properties such as sensitivity and sparsity predict leakage more directly than coarse method labels, and the study evaluates output-level mitigations across multiple explanation families.

6.4 Low-FPR Evaluation

Average accuracy and AUC remain useful for comparison, but privacy attacks are often operationally important in the tail. If an attack identifies 1% of training records with very high confidence and guesses randomly on the rest, its average accuracy can appear benign. Following modern MIA practice,

Table 3: Membership inference attacks using explanations. Low-FPR results are highlighted when available.

Study	Explanation (path)	Membership signal	Modality	Access	Evaluation	Representative finding
Shokri et al. [39]	Gradients; Integrated Gradients; LRP; SmoothGrad; P1	Explanation variance or full vector	Tabular; Image	Prediction + local explanation	Accuracy	Gradient explanations leak membership; full-vector attacks are slightly stronger than variance-only attacks, with leakage shaped by overfitting and dimensionality.
Kuppa and Le-Khac [17]	CF; P1	Proximity to factual and CF neighborhoods	Tabular (security)	Prediction + CF API	Accuracy; queries	Demonstrates CF-assisted membership inference; its evaluation predates current low-FPR MIA practice.
Naretto et al. [27]	Global surrogate; P5	Surrogate behavior	Tabular	Released global explainer	Accuracy; AUC	Global surrogate explanations can leak more membership information than the original classifier; leakage tracks fidelity and overfitting.
Pawelczyk et al. [34]	CF or recourse; P1	CF distance; likelihood ratio	Tabular	One recourse query per record	AUC; balanced accuracy; low-FPR TPR	HELOC+CCHVAE: AUC 0.679 and TPR 5.13% at 1% FPR; several Adult and Diabetes settings remain near random.
Cohen et al. [6]	Self-influence; P4	Self-influence score	Image	Model and training access	Accuracy; AUC	Demonstrates membership leakage from self-influence under a substantially stronger, non-public access model.
Liu et al. [18]	Seven feature-importance methods; P1/P2	Explanation-guided robustness trajectory	Image	Prediction + explanation; shadow variants	AUC; balanced accuracy; TPR at 0.1% FPR	Representative AUC 0.915–0.931 and TPR 2.2–3.7% at 0.1% FPR; ablations show both XAI and the multi-query procedure contribute.
Ma et al. [22]	Feature-importance signal; P2	Neighborhood consistency and recovered confidence	Image	Label-only; 500-query cap	Accuracy; low-FPR TPR; queries	Feature importance guides sampling and supports high-precision attacks on selected forgettable records, trading coverage for precision.
Ezzeddine et al. [9]	CF; P1	CF-augmented attack features	Tabular; Sensor	Prediction + CF; DP and active-learning variants	Accuracy; precision; recall	EEG baseline: accuracy and recall rise from 58% without CF to 77% with CF; DP reduces leakage with a utility cost.
Benhmida et al. [12]	15 methods across four explanation families; P1	Learned explanation-based signal	Image	Prediction + explanation	Membership leakage; explanation utility	Reports up to 74.9% more leakage than prior explanation-MIA baselines; mitigations reduce leakage by 46.5–95% with at most 3.3% average utility loss.

including Pawelczyk et al. [34], Liu et al. [18], and Ma et al. [22], studies should report TPR at fixed low FPR (at least 1% and, where sample size permits, 0.1% or lower), alongside AUC and balanced accuracy. The number of positive and negative evaluation examples must be large enough to support the claimed operating point.

A second reporting issue is per-record versus population-average leakage. Explanation MIA repeatedly finds that outliers, difficult examples, or forgettable records leak more. A single average can therefore hide highly vulnerable subpopulations. Future evaluations should report distributions or stratified leakage, not only one scalar.

Target selection must be reported with the same care. Pawelczyk et al. [34] show recourse configurations that remain close to random even when others leak substantially, whereas Ma et al. [22] deliberately focus on records estimated to be especially vulnerable. These results answer different questions: population-wide risk versus the ability to identify a high-risk subset. When an attack filters candidate records before inference, the paper should report coverage, the selection rule, and whether the information needed for selection is available under the stated threat model. Otherwise, a high TPR can conceal that the attack applies to only a narrow subset or relies on additional knowledge.

Explanation-assisted membership inference spans several mechanisms. Direct explanation statistics, boundary or recourse distance, and explanation-guided robustness each leak

under different conditions. Strong evaluation therefore requires low-FPR metrics, coverage, and an ablation that separates the explanation’s contribution from the attack algorithm’s contribution.

7 Model Inversion

Model inversion presents the most direct personal-data risk in the corpus: explanations are used to reconstruct a private record or a hidden attribute. A critical distinction is *whose data are reconstructed*. Classic model inversion often aims at information memorized in the training set [10]; several explanation attacks instead reconstruct the *query input* represented by an explanation report. The latter risk exists even if the model never memorized that record. Accordingly, the literature uses different evaluation measures: mean absolute error (MAE) for tabular reconstruction, mean-squared error (MSE), structural similarity (SSIM), and peak signal-to-noise ratio (PSNR) for images, and classification accuracy for hidden attributes.

7.1 Spatial Explanations

Zhao et al. [50] show that image explanations can serve as a spatial prior for instance-level inversion. Their multimodal transposed-CNN and U-Net architectures consume a prediction and a saliency or CAM-style map. U-Net bypass con-

Table 4: Comparison of explanation-assisted model inversion studies, including attribute inference as partial inversion. We distinguish reconstruction of training records from reconstruction of query records.

Study	Explanation (path)	Mechanism	Private target	Target models	Evaluation	Representative finding
Zhao et al. [50]	Gradient, CAM, and LRP; P1/P2/P3	Spatial explanation as inversion input	Image records	DNN image classifiers	MSE; SSIM; PSNR; attack accuracy	Spatial explanations improve over prediction-only inversion; richer class-specific CAM sets increase reconstruction risk.
Duddu and Boutet [7]	Feature-importance explanations; P1	Classifier maps explanation to hidden attribute	Tabular records	Four classifier families	Attribute-inference accuracy	Explanations outperform prediction-only inference; leakage remains when the sensitive feature is censored via proxy correlations.
Luo et al. [20]	Shapley report; P1 (calibration), P3 (target)	Learned inverse from local linearity	Tabular query records	Neural network; support vector machine; random forest; gradient-boosted tree	MAE; success rate	Demonstrated on Google, Microsoft, and IBM services; important features and neural networks are generally more vulnerable.
Toma and Kikuchi [42]	Shapley values; P3	Inverse optimization; exact linear case	Tabular query records	Linear and nonlinear models	Error; exact recovery	Exact reconstruction for linear regression with exact Shapley values; empirical risk varies by model and optimizer.

nections preserve spatial information that a flattened explanation loses, increasing reconstruction quality under MSE, SSIM, PSNR, embedding similarity, and downstream attack accuracy. Richer sets of class-specific CAM explanations further increase risk. The security implication is that a saliency map reveals more than feature relevance; its two-dimensional structure can encode enough information about the input to improve image recovery.

The threat model is also notable. Zhao et al. [50] consider prediction and explanation tuples obtained through breached storage, interception, or social sharing, and an independent auxiliary dataset plus black-box API access. This is P3 secondary disclosure, not merely a malicious caller eliciting another person’s explanation. The paper also reconstructs surrogate explanations when the target itself does not expose them, creating a P2 variant. A defense that only authenticates the explanation API addresses the first stage of P1 but not these alternative paths.

7.2 Shapley-Value Inversion

Luo et al. [20] study Shapley-based feature inference against tabular ML services. The attacker first sends its own inputs to learn the relationship between features and Shapley explanations; it then obtains a target user’s explanation report and reconstructs that user’s private input features. The paper evaluates Google Cloud, Microsoft Azure, and IBM AIX360-era services and reports MAE and success rate across neural-network, support-vector-machine, random-forest, and gradient-boosted-tree targets. Neural networks are generally most vulnerable in their experiments, and features with greater model importance are reconstructed more reliably. The attack does not rely on the target record being in the training set. Consequently, training-time anti-memorization defenses do not address the central leakage channel.

Toma and Kikuchi [42] sharpen the same issue theoretically. With exact Shapley values and a linear-regression target, the private input can be reconstructed without error under their

model; experiments on Adult, Bank Marketing, and Credit Card Client examine optimizer and model combinations and approximate settings. The result shows why it is unsafe to speak about “SHAP privacy” without specifying the model and implementation: an exact algebraic relationship in one model family may become an approximate statistical inversion problem in another.

7.3 Attribute Inference as Partial Inversion

Duddu and Boutet [7] infer sensitive attributes such as race or sex from explanations. Their two threat models are especially useful for privacy reasoning. In one, the sensitive attribute appears in model input and training data; in the other, it is censored entirely. Even in the censored setting, proxy features can make explanations distinguishable by the hidden sensitive attribute. Across four datasets and four model families, explanations alone outperform prediction-only attribute inference in the studied settings; concatenating predictions with explanations does not consistently help and can hurt. Thus the explanation can be the primary privacy channel rather than merely an amplifier of confidence-based inference.

Calling attribute inference a subcategory of inversion is useful operationally if we preserve the output distinction: full inversion reconstructs a record or high-dimensional representation, while attribute inference reconstructs selected hidden components. The defense target is the same class of asset, namely private information about an individual input, but the evaluation metric differs. Attribute accuracy must be compared against class-prior and proxy-feature baselines; image inversion needs similarity and semantic metrics rather than raw classification accuracy.

7.4 Evaluation of Reconstruction Risk

Pixel MSE, PSNR, and SSIM, feature MAE, success rate, and attribute accuracy measure different notions of recovery. A visually imperfect face may still preserve identity, and a

low average tabular MAE may hide exact reconstruction of a particularly sensitive feature. Conversely, high SSIM may largely reflect background structure irrelevant to the private property. We therefore recommend pairing reconstruction fidelity with a task-specific privacy metric: re-identification or sensitive-attribute accuracy for images, per-feature success with explicit sensitive-feature analysis for tabular data, and prior-normalized accuracy for attribute inference.

The attacker’s prior is equally important. Luo et al. [20] evaluate both an adversary with auxiliary data from the input distribution and a weaker adversary without that background knowledge; Duddu and Boutet [7] compare explanations against prediction-based attribute inference. Reconstruction results should therefore be reported as improvement over an appropriate prior or prediction-only baseline, not only as absolute error. For Shapley-based attacks, the implementation also matters: Toma and Kikuchi’s [42] exact result assumes exact Shapley values and a linear model, whereas commercial systems generally return approximations. A theoretical exact-recovery result and an empirical attack on approximate reports are complementary evidence, not interchangeable threat models.

Explanation-assisted inversion exposes two distinct privacy problems: leakage about training records and leakage about a live query record. Shapley and image-report attacks show that the latter can arise after a legitimate explanation is generated, making report handling and secondary disclosure part of the threat model.

8 Cross-Attack Analysis

8.1 How Explanations Change the Attack Surface

Across the corpus, explanations play six recurring operational roles: gradient oracle, boundary localization, query guidance, surrogate supervision, membership statistic, and inverse representation. This vocabulary is more informative than calling XAI a primary vector or an amplifier because it names the information the attacker actually uses.

The acquisition path then determines whether that information is exposed by the deployment. P1 relies on a target-released explanation interface; P2 survives if the attacker can derive the signal independently; P3 turns the explanation report itself into sensitive derived data; P4 requires privileged training or model access; and P5 persists after a global artifact has been released. We therefore avoid labeling SHAP, LIME, gradients, or counterfactuals as inherently “end-user” or “owner-only.” Exposure is a property of the deployment, authorization boundary, and recipient. These paths also explain defense failures: feature-level noise may break query guidance while leaving a gradient oracle useful; blurring a counterfactual may reduce boundary information but also degrade recourse; and sanitizing a released explanation does not

stop P2 attacks that derive explanations from predictions. A realistic comparison must therefore state *which* assumption changes: model knowledge, explanation disclosure, auxiliary data, caller identity, or query capability.

8.2 Factors Affecting Leakage

The corpus does not support a universal ranking of explanation methods by privacy risk. Leakage depends first on how closely the released signal matches the attack primitive. Raw gradients can be unusually effective for extraction [23], while processed gradients can remove enough information to reduce MEGEX [24] performance on harder data. Counterfactual extraction benefits from boundary proximity and diversity [2, 15, 45], and inversion benefits from spatially structured explanations when the target is an image [50]. The security question is therefore not whether an explanation is “faithful” in the abstract, but whether it preserves the statistic required by a particular attack.

Model complexity, auxiliary knowledge, and modality are the other recurring factors. Query savings can shrink as targets become more complex [23]; complex trees and weakly informative feature-level explanations require broader coverage in AUTOLYCUS [31]; exact Shapley values can permit algebraic inversion in linear models [42]; and EGSteal [21] reports architecture- and explainer-dependent gains on graphs. Counterfactual extraction remains effective under reduced distribution knowledge [2], membership leakage is shaped by overfitting and record heterogeneity [22, 34, 39], and Shapley-based query-record inversion need not involve a training point at all [20]. Evidence also remains concentrated in tabular and image settings, with much less mature coverage for audio, sequential data, and text or LLM interfaces.

Which explanation types dominate? The corpus is strongly skewed toward *local* explanations: counterfactual/recourse mechanisms appear in eight core studies, while SHAP/Shapley and raw gradients each appear in six. Model-agnostic feature importance and counterfactuals dominate tabular attacks, whereas gradient, CAM, and relevance maps dominate image attacks; graph explanations appear only in recent extraction work. Defense research mirrors this skew, concentrating on feature-importance perturbation, DP explanations, and counterfactual sanitization. Current evidence therefore characterizes local, record-specific explanation channels far better than global or graph explanations.

8.3 Interpreting Reported Results

Several studies find greater leakage when an explanation exposes more attack-relevant information: diverse counterfactuals improve extraction [2], multiple class-specific CAMs improve inversion [50], and raw gradients sharply reduce extraction query requirements [23]. These observations do not

justify a monotonic rule that richer or more faithful explanations always leak more. Processed gradients can weaken MEGEX [24] in some settings; perturbation-based explanations can leak less membership information than raw gradients in Shokri et al.’s [39] experiments; and an explanation that is useful to a human may discard exactly the numerical structure an attack needs. A more defensible conclusion is conditional: additional explanation detail increases risk when it preserves information aligned with the attack’s decision statistic or optimization objective.

A second limitation is comparability. Model-extraction papers report fidelity, task accuracy, and query counts; MIA papers increasingly emphasize TPR at low FPR; inversion papers use feature error, image similarity, or attribute accuracy. Even “one query” is not a consistent unit: a single request for a model-agnostic explanation may trigger many internal model evaluations, while one gradient response can return a high-dimensional vector. We therefore treat reported numbers as evidence within each paper’s threat model rather than as a cross-paper leaderboard. A stronger evaluation should report the external request count, response dimensionality and precision, the number of explanation alternatives returned, and, where it can be measured, the internal target-evaluation cost.

Most importantly, attack performance with explanations is not automatically evidence of *marginal leakage caused by explanations*. A new attack can improve because of a better optimizer, more adaptive queries, a stronger attack model, or additional auxiliary data. Liu et al.’s [18] explanation-free ablation demonstrates this directly: both the explanation and the multi-query perturbation procedure contribute to the final MIA. Results that isolate Eq. 2, such as matched prediction-only versus prediction-plus-explanation variants, are therefore more informative for deciding whether an explanation interface should be exposed.

8.4 Recommended Reporting Practice

Based on these inconsistencies, future explanation-assisted attack evaluations should report:

1. The protected asset and exact attack output;
2. Model knowledge separately from the prediction output;
3. The explanation artifact and its P1–P5 acquisition path;
4. Whether the caller, data subject, and adversary are the same party;
5. Auxiliary or shadow data assumptions and distribution match;
6. External requests and, where meaningful, internal target-evaluation cost;
7. A prediction-only baseline with the remaining attack components held fixed;
8. Family-appropriate metrics, including low-FPR TPR for MIA and fidelity-versus-query curves for extraction;
9. Performance heterogeneity across records, model classes, and modalities;

10. Evaluated defenses together with any disclosure channels that remain open.

9 Defenses

DP, explanation perturbation, query controls, and access control operate at different layers and protect different assets. We include differentially private stochastic gradient descent (DP-SGD) as a training-time defense, but distinguish its training-record guarantee from mechanisms that protect the explanation or the query record. We group defenses by the layer on which they act and ask which acquisition path they can actually close. Table 5 summarizes the evidence.

9.1 Training-Time Defenses

Differentially private training is the strongest general mechanism in our corpus for limiting information about individual training records. Patel et al. [33] make the crucial post-processing argument explicit: if f_D is differentially private with respect to training dataset D , then an explanation computed only from that DP output or model cannot worsen the formal training-data guarantee. Their work separately protects the private *explanation or reference data* used to construct a local explanation, which may not be covered by DP model training.

This distinction prevents an important overclaim. DP-SGD can bound training-membership leakage, but it does not automatically protect a new user’s private query from a Shapley inversion attack, because that query is not the protected training record. Nor is DP designed to preserve proprietary model confidentiality: a DP model can still be functionally extracted. Pawelczyk et al. [34] further note that DP training may move decision boundaries and make recourse less actionable; Liu et al. [18] find that practical DP-SGD configurations reduce MIA but can substantially damage both classification and explanation quality. Formal protection and usable explainability therefore need joint evaluation.

Regularization, dropout, augmentation, and early stopping are useful empirical defenses when MIA is driven by overfitting, but they are not privacy guarantees [37, 40]. They are even less directly matched to query-record inversion or model extraction. Their place in an XAI privacy paper should be as general baselines, not as substitutes for explanation-specific controls.

9.2 Explanation-Layer Defenses

Explanation-layer defenses perturb or redesign the artifact before release. Patel et al.’s [33] DP local explanations provide formal protection for data used during local approximation. Allana and Dara [3] add noise to feature-based explanations and evaluate attribute-inference risk, explanation

Table 5: Defenses relevant to explanation-assisted attacks. Evidence is classified as direct empirical evaluation, a formal privacy argument, or an unvalidated proposal for the corresponding attack family.

Defense	Layer	Primary asset	Evidence	Not automatically covered	Main observation
DP-SGD [1]	Training	Training membership and records	Formal and empirical [18, 33, 34]	Query-record privacy; model confidentiality	When explanations are post-processing of a DP model, the training-data guarantee is preserved; practical utility and explanation-quality loss can be substantial.
Regularization and dropout [40]	Training	Empirical membership leakage	Indirect or general evidence	Formal privacy; query inversion; model extraction	Can reduce overfitting-driven leakage but provides no formal privacy guarantee.
DP local explanations [33]	Explainer	Reference or training data	Formal and empirical analysis	Model confidentiality; unprotected query records	Separates DP of model training from privacy of data used to construct local explanations.
DP counterfactuals [8]	Explainer	Model confidentiality	Model extraction: evaluated	Attacker-derived explanations; other XAI families	Reduces CF-assisted extraction toward no-CF baselines while retaining some recourse utility.
Noise on feature explanations [3]	Explanation	Query-record attributes	Inversion; attribute inference: evaluated	Raw gradients; attacker-derived channels	Evaluates attack success, explanation faithfulness, and model utility jointly.
Clipping, masking, and noise [12]	Explanation	Membership leakage	Membership inference: evaluated	Extraction; inversion unless evaluated	Reduces leakage by 46.5–95% with at most 3.3% average utility loss in DeepLeak.
FGSM-style explanation perturbation [47]	Explanation	Model confidentiality	Model extraction: evaluated	Other attack families; adaptive recovery	Changes DMEAE attack accuracy by only 0.49–0.65 percentage points in the reported settings.
MemGuard [13]	Prediction	Prediction-based membership leakage	Membership inference: evaluated [18]	Explanation channel	Explanation-assisted attacks retain AUC 0.872–0.885 because feature-importance outputs remain unprotected.
Query budgets and auditing (PRADA) [14]	API	Repeated online extraction	Partial or indirect evidence [2, 31]	Low-query and Sybil attacks; secondary disclosure	Raises attack cost, but low-query CF extraction can resemble benign use and queries can be distributed across identities.
Access control and retention	Report	Query-record privacy	Proposed in XAI reviews [4]	Legitimate sharing; attacker-derived explanations	Directly addresses secondary disclosure of sensitive explanation reports.
Faithful Defense [51]	Explainer	Model confidentiality	Model-extraction-oriented design	Training and query-record privacy	Reduces boundary leakage while retaining faithful logical explanations.
XRand [29]	Explanation	Feature-importance disclosure	Evaluated for backdoor guidance	Extraction; MIA; inversion unvalidated	Useful local-DP-style randomization precedent, but published evaluation targets a different attack family.

faithfulness, and predictive utility jointly. DeepLeak [12] evaluates clipping, masking, and calibrated noise over a broader set of explainers. These works point toward the correct optimization target: not “make the explanation noisy,” but remove the attack-relevant statistic while retaining the utility property required by the intended recipient.

The difficulty is attack specificity. DMEAE [47] evaluates a simple FGSM-style perturbation of explanations and observes only 0.49 percentage-point change in SVHN attack accuracy and 0.65 points on CIFAR-10. Perturbation magnitude that visually changes an explanation may leave enough structure for extraction. Conversely, aggressive noise that defeats MIA can make an explanation useless. An explanation defense should therefore report both attack success for the corresponding family and a method-appropriate explanation-quality metric.

Counterfactual privacy adds another trade-off. Ezzeddine et al. [8] integrate DP into a CF generator and observe that private CFs reduce KD-based extraction toward no-CF baselines while retaining some agreement and utility. Aïvodji et al. [2] show that more realistic and diverse CFs improve extraction.

Defenders may therefore need to bound the amount, diversity, or precision of recourse information, but doing so can directly conflict with actionability.

9.3 Prediction-Output Defenses

Liu et al.’s [18] evaluation of MemGuard [13] is an instructive negative result. MemGuard perturbs confidence scores to confuse a prediction-based membership classifier, but does not protect the feature-importance maps. Liu’s explanation-assisted attacks still obtain AUC 0.872–0.885 for LIME, SHAP, Grad-CAM, and SmoothGrad under the evaluated defense. This demonstrates a general principle: protecting one output channel does not protect a parallel explanation channel.

The converse is also true. Explanation sanitization does not necessarily stop prediction-only MIA or extraction. A service that releases both $o(x)$ and $e(x)$ must evaluate the composition. Where multiple explanation formats are available, the strongest joint attack matters, not the strongest single-channel defense.

9.4 Operational Defenses

Query budgets, anomaly detection, and extraction defenses such as PRADA [14] operate at the service boundary. They are naturally relevant to P1 attacks that require repeated adaptive queries. AUTOLYCUS [31] observes that budgets can slow extraction. Aïvodji et al. [2], however, point out that low-query counterfactual extraction can resemble legitimate use and that a Sybil adversary can distribute queries across identities. As explanations make each request more informative, security cannot rely on volume alone.

P3 secondary disclosure requires a different control set: authentication to stored reports, least-privilege authorization, encryption in transit and at rest, retention limits, and audit logging. These are standard systems controls rather than new XAI algorithms, but the threat is XAI-specific because the explanation report may reveal a private input that the prediction does not. The 2025 scoping review likewise recommends role-based explanation access, query restrictions, and monitoring [4]; our contribution is to connect each control to the acquisition paths for which it can be effective.

9.5 Defense Coverage by Acquisition Path

No single mechanism covers all five acquisition paths. P1 requires explanation minimization or sanitization plus identity-aware query controls; P2 additionally requires defenses on predictions and resistance to surrogate construction; P3 requires treating explanation reports as sensitive data with storage, access, retention, and sharing controls; P4 requires restricting training and model artifacts and auditor privileges; and P5 requires privacy evaluation before irreversible artifact release. Defenses should therefore be composed around the acquisition paths that are present in the deployment.

A defense claim should name the protected asset and the acquisition path it closes. “Privacy-preserving XAI” is too broad when a mechanism protects training membership but not query inversion, or sanitizes target explanations while attacker-derived explanations remain available.

10 Research Gaps and Open Problems

Standardized marginal and compositional leakage. The field needs matched experiments in which the target, auxiliary knowledge, attack algorithm, and query budget are fixed while only the explanation channel changes, making Δ_{XAI} in Eq. 2 measurable. Real services also expose multiple channels; evaluation should test $o(x)$, each $e_i(x)$, and their composition rather than infer safety from one protected output.

Query-record privacy. Training privacy dominates ML privacy research, but Luo et al. [20], Zhao et al. [50], Toma and Kikuchi [42], and Duddu and Boutet [7] show that an explanation can leak a record that was never in training. Formal

mechanisms need an explicit adjacency or sensitivity notion for the *explained input*, and for any private reference data used to construct the explanation, not only for the model’s training set.

Modalities and adaptive acquisition. Graph extraction has begun to appear [21], but audio, sequential data, and text or LLM explanation interfaces are sparsely covered by mature privacy attacks. At the same time, output sanitization is often evaluated against a fixed attacker; repeated noisy explanations can be aggregated and attackers can switch to P2 surrogate-derived explanations. Both gaps require modality-specific, adaptive evaluation rather than extrapolation from image and tabular results.

Interface-aware leakage benchmarks. The next step beyond per-paper query counts is a benchmark that fixes the target task and exposes controlled interfaces, for example label only, scores, feature-importance explanations, and counterfactuals, under matched auxiliary knowledge. Such a benchmark would make it possible to compare both marginal leakage and operational cost without pretending that different explanation responses carry equivalent information.

11 Related Surveys and SoKs

Nguyen et al. [28] survey privacy attacks and countermeasures by explanation type, while Allana et al. [4] review privacy-preserving XAI more broadly. Nadeem et al. [26], Noppel and Wressnegger [30], and Pawlicki et al. [35] cover broader XAI security or adversarial themes; Rigaki and Garcia [37] survey ML privacy more generally. Our narrower contribution is operational: we separate model knowledge from *how the explanation is acquired*, trace each signal to its attack mechanism and protected asset, and map defenses to the paths they can close.

12 Conclusion

The central lesson of this SoK is that the privacy cost of explainability is determined by the *information path*, not by an explanation method alone. Across 25 core studies, explanations reduce extraction cost, expose membership signals, and support reconstruction of private inputs and attributes, but no explanation family is uniformly unsafe. Security claims should identify the protected asset, prediction output, explanation artifact, acquisition path, auxiliary knowledge, and query budget. Defenses require the same discipline: DP training protects training records; sanitization acts on released explanations; service controls constrain online acquisition; and report handling addresses secondary disclosure. This end-to-end view makes attack assumptions, marginal leakage, and defense coverage explicit.

A Open Science

This paper systematizes published literature and does not introduce a new attack implementation, dataset, trained model, or benchmark. The underlying evidence is contained in the cited papers and in the study classifications reported in Tables 1–5. We therefore do not provide a separate research artifact.

B Ethical Considerations

The paper analyzes previously published attacks and defenses and does not introduce a new exploit. Its main risk is that consolidating effective leakage channels could reduce the effort needed to compare prior offensive techniques. We mitigate this by reporting only information already present in the literature and by emphasizing threat-model limits, defensive coverage, and deployment safeguards. The intended benefit is to help model owners and privacy researchers identify which explanation disclosures require protection and avoid overclaiming defenses whose guarantees do not match the protected asset.

References

- [1] Martin Abadi, Andy Chu, Ian Goodfellow, H. Brendan McMahan, Ilya Mironov, Kunal Talwar, and Li Zhang. Deep learning with differential privacy. In *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security*, CCS '16, page 308–318, New York, NY, USA, 2016. Association for Computing Machinery.
- [2] Ulrich Aïvodji, Alexandre Bolot, and Sébastien Gambs. Model extraction from counterfactual explanations, 2020.
- [3] Sonal Allana and Rozita Dara. Privacy preservation with noise in explainable AI. In *22nd Annual International Conference on Privacy, Security, and Trust, PST 2025, Fredericton, NB, Canada, August 26-28, 2025*, pages 1–8. IEEE, 2025.
- [4] Sonal Allana, Mohan Kankanhalli, and Rozita Dara. Privacy risks and preservation methods in explainable artificial intelligence: A scoping review. *Trans. Mach. Learn. Res.*, 2025, 2025.
- [5] Sebastian Bach, Alexander Binder, Grégoire Montavon, Frederick Klauschen, Klaus-Robert Müller, and Wojciech Samek. On pixel-wise explanations for non-linear classifier decisions by layer-wise relevance propagation. *PloS one*, 10(7):e0130140, 2015.
- [6] Gilad Cohen and Raja Giryes. Membership inference attack using self influence functions. In *IEEE/CVF Winter Conference on Applications of Computer Vision, WACV 2024, Waikoloa, HI, USA, January 3-8, 2024*, pages 4880–4889. IEEE, 2024.
- [7] Vasisht Duddu and Antoine Boutet. Inferring sensitive attributes from model explanations. In Mohammad Al Hasan and Li Xiong, editors, *Proceedings of the 31st ACM International Conference on Information & Knowledge Management, Atlanta, GA, USA, October 17-21, 2022*, pages 416–425. ACM, 2022.
- [8] Fatima Ezzeddine, Omran Ayoub, and Silvia Giordano. Knowledge distillation-based model extraction attack using GAN-based private counterfactual explanations. In *NeurIPS 2024 Workshop on Regulatable ML*, 2024.
- [9] Fatima Ezzeddine, Osama Zammar, Silvia Giordano, and Omran Ayoub. Explanations leak: Membership inference with differential privacy and active learning defense. *CoRR*, abs/2602.03611, 2026.
- [10] Matt Fredrikson, Somesh Jha, and Thomas Ristenpart. Model inversion attacks that exploit confidence information and basic countermeasures. In *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security*, CCS '15, page 1322–1333, New York, NY, USA, 2015. Association for Computing Machinery.
- [11] Sofie Goethals, Kenneth Sörensen, and David Martens. The privacy issue of counterfactual explanations: Explanation linkage attacks. *ACM Trans. Intell. Syst. Technol.*, 14(5):83:1–83:24, 2023.
- [12] Firas Ben Hmida, Zain Sbeih, Philemon Hailemariam, and Birhanu Eshete. DeepLeak: Privacy Enhancing Hardening of Model Explanations Against Membership Leakage. In *2026 IEEE Conference on Secure and Trustworthy Machine Learning (SaTML)*, 2026.
- [13] Jinyuan Jia, Ahmed Salem, Michael Backes, Yang Zhang, and Neil Zhenqiang Gong. MemGuard: Defending against black-box membership inference attacks via adversarial examples. In *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security*, CCS '19, page 259–274, New York, NY, USA, 2019. Association for Computing Machinery.
- [14] Mika Juuti, Sebastian Szyller, Samuel Marchal, and N. Asokan. PRADA: protecting against DNN model stealing attacks. In *IEEE European Symposium on Security and Privacy, EuroS&P 2019, Stockholm, Sweden, June 17-19, 2019*, pages 512–527, USA, 2019. IEEE.

- [15] Awa Khouna, Julien Ferry, and Thibaut Vidal. From counterfactuals to trees: Competitive analysis of model extraction attacks. In D. Belgrave, C. Zhang, H. Lin, R. Pascanu, P. Koniusz, M. Ghassemi, and N. Chen, editors, *Advances in Neural Information Processing Systems*, volume 38, pages 2721–2756. Curran Associates, Inc., 2025.
- [16] Pang Wei Koh and Percy Liang. Understanding black-box predictions via influence functions. In Doina Precup and Yee Whye Teh, editors, *Proceedings of the 34th International Conference on Machine Learning, ICML 2017, Sydney, NSW, Australia, 6-11 August 2017*, volume 70 of *Proceedings of Machine Learning Research*, pages 1885–1894. PMLR, 2017.
- [17] Aditya Kuppa and Nhien-An Le-Khac. Adversarial XAI methods in cybersecurity. *IEEE Trans. Inf. Forensics Secur.*, 16:4924–4938, 2021.
- [18] Han Liu, Yuhao Wu, Zhiyuan Yu, and Ning Zhang. Please Tell Me More: Privacy Impact of Explainability through the Lens of Membership Inference Attack. In *2024 IEEE Symposium on Security and Privacy (SP)*, pages 4791–4809, Los Alamitos, CA, USA, May 2024. IEEE Computer Society.
- [19] Scott M. Lundberg and Su-In Lee. A unified approach to interpreting model predictions. In *Proceedings of the 31st International Conference on Neural Information Processing Systems, NIPS’17*, page 4768–4777, Red Hook, NY, USA, 2017. Curran Associates Inc.
- [20] Xinjian Luo, Yangfan Jiang, and Xiaokui Xiao. Feature inference attack on shapley values. In Heng Yin, Angelos Stavrou, Cas Cremers, and Elaine Shi, editors, *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security, CCS 2022, Los Angeles, CA, USA, November 7-11, 2022*, pages 2233–2247. ACM, 2022.
- [21] Bin Ma, Yuyuan Feng, Minhua Lin, and Enyan Dai. How explanations leak the decision logic: Stealing graph neural networks via explanation alignment. *CoRR*, abs/2506.03087, 2025.
- [22] Yao Ma, Xurong Zhai, Dan Yu, Yuli Yang, Xingyu Wei, and Yongle Chen. Label-only membership inference attack based on model explanation. *Neural Process. Lett.*, 56(5):236, 2024.
- [23] Smitha Milli, Ludwig Schmidt, Anca D. Dragan, and Moritz Hardt. Model reconstruction from model explanations. In *Proceedings of the Conference on Fairness, Accountability, and Transparency, FAT* ’19*, page 1–9, New York, NY, USA, 2019. Association for Computing Machinery.
- [24] Takayuki Miura, Toshiki Shibahara, and Naoto Yanai. MEGEX: Data-free model extraction attack against gradient-based explainable AI. In *Proceedings of the 2nd ACM Workshop on Secure and Trustworthy Deep Learning Systems, SecTL ’24*, page 56–66, New York, NY, USA, 2024. Association for Computing Machinery.
- [25] Ramaravind Kommiya Mothilal, Amit Sharma, and Chenhao Tan. Explaining machine learning classifiers through diverse counterfactual explanations. In Mireille Hildebrandt, Carlos Castillo, L. Elisa Celis, Salvatore Ruggieri, Linnet Taylor, and Gabriela Zanfir-Fortuna, editors, *FAT* ’20: Conference on Fairness, Accountability, and Transparency, Barcelona, Spain, January 27-30, 2020*, pages 607–617. ACM, 2020.
- [26] Azqa Nadeem, Daniël Vos, Clinton Cao, Luca Pajola, Simon Dieck, Robert Baumgartner, and Sicco Verwer. SoK: Explainable Machine Learning for Computer Security Applications. In *2023 IEEE 8th European Symposium on Security and Privacy (EuroS&P)*, pages 221–240, 2023.
- [27] Francesca Naretto, Anna Monreale, and Fosca Giannotti. Evaluating the privacy exposure of interpretable global explainers. In *4th IEEE International Conference on Cognitive Machine Intelligence, CogMI 2022, Atlanta, GA, USA, December 14-17, 2022*, pages 13–19. IEEE, 2022.
- [28] Thanh Tam Nguyen, Thanh Trung Huynh, Zhao Ren, Thanh Toan Nguyen, Phi Le Nguyen, Hongzhi Yin, and Quoc Viet Hung Nguyen. Privacy-preserving explainable AI: a survey. *Sci. China Inf. Sci.*, 68(1), 2025.
- [29] Truc D. T. Nguyen, Phung Lai, Hai Phan, and My T. Thai. XRand: Differentially private defense against explanation-guided attacks. In Brian Williams, Yiling Chen, and Jennifer Neville, editors, *Thirty-Seventh AAAI Conference on Artificial Intelligence, AAAI 2023, Thirty-Fifth Conference on Innovative Applications of Artificial Intelligence, IAAI 2023, Thirteenth Symposium on Educational Advances in Artificial Intelligence, EAAI 2023, Washington, DC, USA, February 7-14, 2023*, pages 11873–11881. AAAI Press, 2023.
- [30] Maximilian Noppel and Christian Wressnegger. SoK: Explainable Machine Learning in Adversarial Environments. In *2024 IEEE Symposium on Security and Privacy (SP)*, pages 2441–2459, 2024.
- [31] Abdullah Caglar Oksuz, Anisa Halimi, and Erman Ayday. AUTOLYCUS: exploiting explainable artificial intelligence (XAI) for model extraction attacks against interpretable models. *Proc. Priv. Enhancing Technol.*, 2024(4):684–699, 2024.

- [32] Daan Otto, Jannis Kurtz, Dick den Hertog, and S. Ilker Birbil. Linear model extraction via factual and counterfactual queries. *CoRR*, abs/2602.09748, 2026.
- [33] Neel Patel, Reza Shokri, and Yair Zick. Model explanations with differential privacy. In *FACCT '22: 2022 ACM Conference on Fairness, Accountability, and Transparency, Seoul, Republic of Korea, June 21 - 24, 2022*, pages 1895–1904. ACM, 2022.
- [34] Martin Pawelczyk, Himabindu Lakkaraju, and Seth Neel. On the privacy risks of algorithmic recourse. In Francisco J. R. Ruiz, Jennifer G. Dy, and Jan-Willem van de Meent, editors, *International Conference on Artificial Intelligence and Statistics, 25-27 April 2023, Palau de Congressos, Valencia, Spain*, volume 206 of *Proceedings of Machine Learning Research*, pages 9680–9696. PMLR, 2023.
- [35] Marek Pawlicki, Ryszard S. Choras, Rafal Kozik, and Michal Choras. Survey on explainability-weaponising adversarial attack vectors against deep neural networks and artificial intelligence. In Ana Paula Rocha, Mattias Wahde, and H. Jaap van den Herik, editors, *Proceedings of the 18th International Conference on Agents and Artificial Intelligence, ICAART 2026 - Volume 2, Marbella, Spain, March 5-7, 2026*, pages 1361–1370. SCITEPRESS, 2026.
- [36] Marco Tulio Ribeiro, Sameer Singh, and Carlos Guestrin. "why should i trust you?": Explaining the predictions of any classifier. In *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining, KDD '16*, page 1135–1144, New York, NY, USA, 2016. Association for Computing Machinery.
- [37] Maria Rigaki and Sebastian García. A survey of privacy attacks in machine learning. *ACM Comput. Surv.*, 56(4):101:1–101:34, 2024.
- [38] Ramprasaath R. Selvaraju, Michael Cogswell, Abhishek Das, Ramakrishna Vedantam, Devi Parikh, and Dhruv Batra. Grad-CAM: Visual explanations from deep networks via gradient-based localization. In *IEEE International Conference on Computer Vision, ICCV 2017, Venice, Italy, October 22-29, 2017*, pages 618–626, USA, 2017. IEEE Computer Society.
- [39] Reza Shokri, Martin Strobel, and Yair Zick. On the privacy risks of model explanations. In Marion Fourcade, Benjamin Kuipers, Seth Lazar, and Deirdre K. Mulligan, editors, *AIES '21: AAAI/ACM Conference on AI, Ethics, and Society, Virtual Event, USA, May 19-21, 2021*, pages 231–241, USA, 2021. ACM.
- [40] Nitish Srivastava, Geoffrey E. Hinton, Alex Krizhevsky, Ilya Sutskever, and Ruslan Salakhutdinov. Dropout: a simple way to prevent neural networks from overfitting. *J. Mach. Learn. Res.*, 15(1):1929–1958, 2014.
- [41] Mukund Sundararajan, Ankur Taly, and Qiqi Yan. Axiomatic attribution for deep networks. In Doina Precup and Yee Whye Teh, editors, *Proceedings of the 34th International Conference on Machine Learning, ICML 2017, Sydney, NSW, Australia, 6-11 August 2017*, volume 70 of *Proceedings of Machine Learning Research*, pages 3319–3328, USA, 2017. PMLR.
- [42] Ryotaro Toma and Hiroaki Kikuchi. Combinations of AI models and XAI metrics vulnerable to record reconstruction risk. In Josep Domingo-Ferrer and Melek Önen, editors, *Privacy in Statistical Databases - International Conference, PSD 2024, Antibes Juan-les-Pins, France, September 25-27, 2024, Proceedings*, volume 14915 of *Lecture Notes in Computer Science*, pages 329–343. Springer, 2024.
- [43] Sandra Wachter, Brent Mittelstadt, and Chris Russell. Counterfactual explanations without opening the black box: Automated decisions and the GDPR. *Harvard Journal of Law & Technology*, 31(2):841–887, 2018.
- [44] Aidmar Wainakh, Till Müßig, Tim Grube, and Max Mühlhäuser. Label leakage from gradients in distributed machine learning. In *18th IEEE Annual Consumer Communications & Networking Conference, CCNC 2021, Las Vegas, NV, USA, January 9-12, 2021*, pages 1–4. IEEE, 2021.
- [45] Yongjie Wang, Hangwei Qian, and Chunyan Miao. DualCF: Efficient model extraction attack from counterfactual explanations. In *FACCT '22: 2022 ACM Conference on Fairness, Accountability, and Transparency, Seoul, Republic of Korea, June 21 - 24, 2022*, pages 1318–1329, USA, 2022. ACM.
- [46] Anli Yan, Ruitao Hou, Xiaozhang Liu, Hongyang Yan, Teng Huang, and Xianmin Wang. Towards explainable model extraction attacks. *Int. J. Intell. Syst.*, 37(11):9936–9956, 2022.
- [47] Anli Yan, Ruitao Hou, Hongyang Yan, and Xiaozhang Liu. Explanation-based data-free model extraction attacks. *World Wide Web (WWW)*, 26(5):3081–3092, 2023.
- [48] Anli Yan, Teng Huang, Lishan Ke, Xiaozhang Liu, Qi Chen, and Changyu Dong. Explanation leaks: Explanation-guided model extraction attacks. *Information Sciences*, 632:269–284, 2023.
- [49] Bo Zhao, Konda Reddy Mopuri, and Hakan Bilen. iDLG: Improved deep leakage from gradients. *CoRR*, abs/2001.02610, 2020.

- [50] Xuejun Zhao, Wencan Zhang, Xiaokui Xiao, and Brian Y. Lim. Exploiting explanations for model inversion attacks. In *2021 IEEE/CVF International Conference on Computer Vision, ICCV 2021, Montreal, QC, Canada, October 10-17, 2021*, pages 662–672, USA, 2021. IEEE.
- [51] Chudi Zhong, Panyu Chen, and Cynthia Rudin. Models that are interpretable but not transparent. In Yingzhen Li, Stephan Mandt, Shipra Agrawal, and Mohammad Emtiyaz Khan, editors, *International Conference on Artificial Intelligence and Statistics, AISTATS 2025, Mai Khao, Thailand, 3-5 May 2025*, volume 258 of *Proceedings of Machine Learning Research*, pages 1648–1656. PMLR, 2025.
- [52] Ligeng Zhu, Zhijian Liu, and Song Han. Deep leakage from gradients. In Hanna M. Wallach, Hugo Larochelle, Alina Beygelzimer, Florence d’Alché-Buc, Emily B. Fox, and Roman Garnett, editors, *Advances in Neural Information Processing Systems 32: Annual Conference on Neural Information Processing Systems 2019, NeurIPS 2019, December 8-14, 2019, Vancouver, BC, Canada*, pages 14747–14756, 2019.